

MITRE ATT&CK Framework

The MITRE ATT&CK Framework is used in cybersecurity to understand how attackers behave during real cyberattacks. Instead of focusing only on malware, it explains the steps an attacker follows from collecting information to causing damage. These notes are my understanding of the framework and its major tactics.

TACTICS AND THERE TECHNIQUES

1. Reconnaissance (TA0043)

What the Tactic Represents

This is the first stage of attack where attackers gather information before a attack , they scan for open ports , websites , gather employee info etc , it helps attackers to attack and cause more damage

Techniques,

T1595 – Active Scanning

Active scanning means checking a target system to find open ports and running services. Attackers use tools like Nmap to gather information and identify possible security weaknesses before attacking.

T1589 – Gather Victim Identity Information

Gather Victim Identity Information means collecting details about the target, like names, email addresses, and job roles. Attackers use this information to plan targeted phishing or social engineering attacks.

T1598 – Phishing for Information

Phishing for Information is when attackers use fake emails or messages to fool people into giving personal or confidential information. This information is later used to carry out cyberattacks.

Threat Actor

APT29 (Cozy Bear) is known for conducting extensive reconnaissance before launching attacks. The group carefully gathers information about government agencies and organizations to create highly convincing spear-phishing campaigns.

SOC Detection Method

SOC analysts monitor for repeated scanning attempts from external IP addresses, unusual DNS queries, and large volumes of requests targeting public-facing systems. This is how an SOC team can detect reconnaissance

2. Resource Development (TA0042)

What the Tactic Represents

Resource Development is the stage where attackers prepare everything they need before attacking the target. They create or collect tools, malware, fake websites, domains, and servers to make the attack successful. Techniques

T1583 – Acquire Infrastructure

Attackers buy or rent servers, domain names, or cloud services that will be used to host malware, phishing websites, or command-and-control servers. This helps them hide their real identity.

T1587 – Develop Capabilities

Attackers create or modify malware, phishing kits, exploits, or other hacking tools. They often improve these tools so they can bypass security software.

T1608 – Stage Capabilities

Attackers upload malware, phishing files, or other malicious tools to websites or cloud storage before sending them to victims. This makes the attack faster and easier to launch.

Threat Actor

APT41 is well known for developing custom malware and building attack infrastructure. The group uses these resources for both cyber espionage and financial attacks.

SOC Detection Method

SOC analysts monitor newly registered suspicious domains, malicious websites, and communication with known attacker servers. Threat intelligence and security tools help detect these resources before they are used in an attack.

3. Initial Access (TA0001)

What the Tactic Represents

Initial Access is the stage where attackers enter the victim's system or network for the first time. They may use phishing emails, stolen passwords, or software vulnerabilities to gain access.. Once initial access is achieved, attackers begin establishing control over the compromised system.

Techniques

T1566 – Phishing

Attackers send fake emails or messages with malicious links or attachments. When the victim clicks the link or opens the file, the attacker gains access to the system

T1190 – Exploit Public-Facing Application

Attackers exploit security weaknesses in internet-facing applications such as websites, web servers, or VPNs. If the vulnerability is not patched, they can enter the organization's network.

T1133 – External Remote Services

Attackers use stolen usernames and passwords to log in through remote access services like VPN, SSH, or RDP. Since valid credentials are used, the login may appear normal.

Threat Actor

FIN7 commonly uses phishing emails to gain initial access to organizations. The group targets employees with convincing emails to steal credentials or install malware.

SOC Detection Method

SOC analysts monitor suspicious email activity, repeated failed login attempts, unusual VPN/SSH/RDP logins, and access from unknown locations or devices. Security tools generate alerts when abnormal login behavior is detected..

4. Execution (TA0002)

What the Tactic Represents

Execution is the stage where attackers run malicious code on the victim's system. This allows malware or harmful commands to start working and perform actions such as downloading files, stealing data, or taking control of the system.

Techniques

T1059 – Command and Scripting Interpreter

Attackers use command-line tools like PowerShell, Command Prompt, or Bash to run malicious commands, execute scripts, or download malware.

T1204 – User Execution

Attackers trick users into opening a malicious file, clicking a harmful link, or installing an infected program. The attack starts only after the user performs the action.

T1047 – Windows Management Instrumentation (WMI)

Attackers misuse Windows Management Instrumentation (WMI), a legitimate Windows administration tool, to execute commands or malware on local or remote systems without attracting much attention

Threat Actor

Lazarus Group often uses PowerShell scripts, WMI, and other Windows tools to execute malware after gaining access to a victim's system.

SOC Detection Method

SOC analysts monitor PowerShell activity, command-line logs, WMI execution, and unusual process creation. Endpoint Detection and Response (EDR) tools help identify suspicious commands and malicious execution quickly.

5. Persistence (TA0003)

What the Tactic Represents

Persistence is the stage where attackers make sure they can continue accessing a compromised system even after it is restarted or the user logs out. They create methods that allow them to return without repeating the initial attack.

Techniques

T1547 – Boot or Logon Autostart Execution

Attackers configure malware to start automatically whenever the computer boots or a user logs in. They may use startup folders, registry keys, or system services

T1136 – Create Account

Attackers create new user accounts, often with administrator privileges, to maintain access. These accounts may remain hidden and can be used if the original compromised account is detected.

T1053 – Scheduled Task/Job

Attackers create scheduled tasks (or cron jobs in Linux) to automatically run malicious programs at specific times or when certain events occur. This helps them maintain long-term access to the system.

Threat Actor

APT29 (Cozy Bear) is known for using scheduled tasks, registry changes, and hidden accounts to maintain long-term access during cyber espionage operations.

SOC Detection Method

SOC analysts monitor for newly created user accounts, scheduled tasks, startup folder changes, and registry modifications. EDR tools and security logs help detect unauthorized persistence mechanisms before attackers can continue their activities.

6. Privilege Escalation (TA0004)

What the Tactic Represents

Privilege Escalation is the stage where attackers try to gain higher permissions after entering a system. By becoming an administrator or root user, they can access sensitive data, disable security tools, and take full control of the system.

Techniques

T1068 – Exploitation for Privilege Escalation

Attackers exploit security vulnerabilities in the operating system or installed software to gain administrator or root privileges. This allows them to perform actions that normal users cannot.

T1548 – Abuse Elevation Control Mechanism

Attackers bypass security features such as User Account Control (UAC) in Windows or Linux privilege controls to obtain higher permissions and run malicious programs with

administrative rights.

T1134 – Access Token Manipulation

Attackers steal or manipulate authentication tokens of privileged users. By using these tokens, they can act as an administrator without knowing the user's password.

Threat Actor

FIN7 is known for using privilege escalation techniques after gaining initial access. The group exploits vulnerabilities and abuses Windows security features to obtain administrator privileges before stealing data or deploying ransomware.

SOC Detection Method

SOC analysts monitor for unusual privilege changes, unexpected administrator logins, UAC bypass attempts, and processes requesting elevated permissions. Security logs and Endpoint Detection and Response (EDR) tools help detect unauthorized privilege escalation activities.

7. Defense Evasion (TA0005)

What the Tactic Represents

Defense Evasion is the stage where attackers try to hide their activities from security software and SOC analysts. They use different techniques to avoid being detected while continuing their attack inside the victim's system.

Techniques

T1027 – Obfuscated Files or Information

Attackers hide or modify malware by encrypting, compressing, or encoding it. This makes it harder for antivirus software and security tools to detect the malicious file.

T1070 – Indicator Removal on Host

Attackers delete event logs, temporary files, and command history to remove evidence of their actions. This makes it more difficult for security teams to investigate the attack.

T1218 – Signed Binary Proxy Execution

Attackers misuse trusted Windows programs such as regsvr32, rundll32, or mshta to run malicious code. Since these are legitimate system tools, their activity may look normal and avoid detection.

Threat Actor

APT41 is known for using defense evasion techniques such as malware obfuscation, log deletion, and trusted Windows utilities to remain hidden during cyberattacks.

SOC Detection Method

SOC analysts monitor for deleted logs, unusual use of trusted system tools, encoded PowerShell commands, and attempts to bypass antivirus software. EDR and SIEM solutions help detect suspicious behavior that traditional signature-based detection may miss.

8. Credential Access (TA0006)

What the Tactic Represents

Credential Access is the stage where attackers try to steal usernames, passwords, authentication tokens, or password hashes. These stolen credentials help them log in to systems, move through the network, and access sensitive information.

Techniques

T1003 – OS Credential Dumping

Attackers extract usernames and password hashes stored in the operating system, especially from the LSASS process in Windows. These credentials can later be cracked or reused to gain unauthorized access.

T1110 – Brute Force

Attackers repeatedly try different username and password combinations until they find the correct one. This technique is commonly used against SSH, VPN, RDP, and web applications with weak passwords.

T1555 – Credentials from Password Stores

Attackers steal saved usernames and passwords from web browsers, password managers, or other applications that store login credentials. These stolen credentials can then be used to access other systems and accounts.

Threat Actor

Lazarus Group is known for stealing credentials using credential dumping, password theft, and brute-force attacks. The group uses these stolen credentials to gain access to sensitive systems and expand its control within a network.

SOC Detection Method

SOC analysts monitor for repeated failed login attempts, unusual authentication activity, access to the LSASS process, and the execution of credential-dumping tools. EDR and SIEM solutions help detect suspicious credential theft and unauthorized login attempts.

9. Discovery (TA0007)

What the Tactic Represents

Discovery is the stage where attackers explore the compromised system and network to understand the environment. They collect information about users, computers, network settings, and running services to plan their next steps.

Techniques

T1082 – System Information Discovery

Attackers gather details about the operating system, computer name, hardware, installed software, and system configuration. This helps them identify weaknesses and choose suitable attack methods.

T1016 – System Network Configuration Discovery

Attackers check the network configuration, including IP addresses, DNS settings, gateways, and network interfaces. This helps them understand the network layout and locate other systems.

T1046 – Network Service Discovery

Attackers scan the network to find active services such as SSH, HTTP, SMB, RDP, and FTP. By identifying these services, they can find potential targets for further attacks.

Threat Actor

APT29 (Cozy Bear) is known for performing detailed discovery after gaining access to a network. The group carefully studies the victim's environment before moving to important systems or stealing sensitive data.

SOC Detection Method

SOC analysts monitor for unusual system information commands, internal network scanning, service enumeration, and unexpected discovery activities. SIEM and **EDR** solutions help detect these behaviors and alert security teams before attackers move to the next stage.

10. Lateral Movement (TA0008)

What the Tactic Represents

Lateral Movement is the stage where attackers move from one compromised system to another within the same network. Their goal is to reach important systems such as servers, databases, or domain controllers and increase their control over the network.

Techniques

T1021 – Remote Services

Attackers use remote access services such as RDP (Remote Desktop Protocol), SSH (Secure Shell), SMB (Server Message Block), or WinRM (Windows Remote Management) to access other computers in the network. They often use stolen credentials to log in.

T1550 – Use Alternate Authentication Material

Instead of using passwords, attackers use stolen authentication tokens, Kerberos tickets, or NTLM password hashes to access other systems. This allows them to move across the network without knowing the user's actual password.

T1570 – Lateral Tool Transfer

Attackers copy malware, scripts, or hacking tools from one compromised machine to another. This helps them continue the attack without downloading files from the internet, reducing the chance of detection.

Threat Actor

FIN7 is known for using lateral movement techniques after gaining administrator access. The group uses stolen credentials and remote administration tools to spread across the network before stealing sensitive data or deploying ransomware.

SOC Detection Method

SOC analysts monitor unusual RDP, SSH, SMB, and WinRM logins, unexpected file transfers between internal systems, and suspicious authentication attempts. SIEM and EDR solutions help detect abnormal lateral movement and alert security teams quickly.

11. Collection (TA0009)

What the Tactic Represents

Collection is the stage where attackers gather valuable information from the compromised system before sending it outside the organization. The collected data may include documents, emails, passwords, databases, and other sensitive files.

Techniques

T1005 – Data from Local System

Attackers search the local computer for important files such as documents, spreadsheets, databases, and configuration files. They collect this information and store it before transferring it to another location.

T1114 – Email Collection

Attackers access email accounts or mail servers to steal emails, attachments, contact lists, and confidential business information. This data can be used for espionage or financial gain.

T1119 – Automated Collection

Attackers use malware or scripts to automatically search for and collect sensitive files from multiple systems. This helps them gather large amounts of data quickly without much manual effort.

Threat Actor

APT41 is known for collecting confidential business documents, intellectual property, and sensitive organizational data during cyber espionage campaigns. The group often uses automated tools to collect data efficiently.

SOC Detection Method

SOC analysts monitor unusual file access, large numbers of file reads, abnormal email activity, and automated scripts accessing sensitive folders. Data Loss Prevention (DLP), Endpoint Detection and Response (EDR), and SIEM solutions help detect suspicious data collection before it is stolen.

12. Command and Control (TA0011)

What the Tactic Represents

Command and Control (C2) is the stage where attackers establish communication between the compromised system and their own server. This allows them to send commands, receive stolen data, download additional malware, and control the infected system remotely.

Techniques

T1071 – Application Layer Protocol

Attackers use common network protocols such as HTTP, HTTPS, DNS, or SMTP to communicate with their command-and-control server. Since these protocols are commonly

used, the malicious traffic can blend in with normal network activity.

T1090 – Proxy

Attackers route their communication through one or more proxy servers to hide their real IP address and make it difficult for security teams to trace the source of the attack.

T1573 – Encrypted Channel

Attackers use **TLS**, **SSL**, or other encryption methods to secure communication between the infected system and the command-and-control server. Encryption prevents defenders from easily viewing the transmitted data.

Threat Actor

Lazarus Group is known for using encrypted command-and-control channels to communicate with compromised systems. The group often disguises malicious traffic as normal **HTTPS** traffic to avoid detection and maintain long-term access.

SOC Detection Method

SOC analysts monitor unusual outbound network connections, repeated communication with unknown domains, periodic beaconing behavior, and encrypted traffic to suspicious IP addresses. Network Detection and Response (NDR), SIEM, and EDR solutions help identify command-and-control activity and alert security teams.

13. Exfiltration (TA0010)

What the Tactic Represents

Exfiltration is the stage where attackers transfer the stolen data from the victim's system to a location they control. The stolen data may include confidential documents, customer information, financial records, or login credentials. Attackers often use encrypted channels or cloud storage to avoid detection.

Techniques

T1041 – Exfiltration Over C2 Channel

Attackers send the stolen data through an existing Command and Control (C2) channel. Since the communication channel is already active, the data transfer is less likely to attract attention.

T1020 – Automated Exfiltration

Attackers use malware or automated scripts to continuously collect and transfer sensitive data without manual intervention. This allows them to steal large amounts of information over time.

T1567 – Exfiltration to Cloud Storage

Attackers upload stolen files to cloud storage services such as Google Drive, Dropbox, or OneDrive. Because these services are commonly used by organizations, the data transfer may appear to be normal business activity.

Threat Actor

APT29 (Cozy Bear) is known for stealing sensitive government and organizational data using encrypted communication channels and trusted cloud services. This helps the group remain hidden while transferring stolen information.

SOC Detection Method

SOC analysts monitor large outbound data transfers, unusual uploads to cloud storage, abnormal network traffic outside business hours, and unexpected movement of sensitive files. Data Loss Prevention (DLP), SIEM, and Network Detection and Response (NDR) solutions help detect unauthorized data exfiltration and alert security teams.

14. Impact (TA0040)

What the Tactic Represents

Impact is the final stage of a cyberattack where attackers try to damage the victim's systems, data, or business operations. They may encrypt files, delete important data, or shut down systems to cause maximum disruption.

Techniques

T1486 – Data Encrypted for Impact

Attackers encrypt files on the victim's computer or network and demand a ransom to restore access. This technique is commonly used in ransomware attacks.

T1490 – Inhibit System Recovery

Attackers delete backups, restore points, or shadow copies to prevent the victim from recovering lost or encrypted data. This makes recovery more difficult and increases the damage.

T1529 – System Shutdown/Reboot

Attackers force systems to shut down or restart unexpectedly. This disrupts normal business operations, causes downtime, and may lead to data loss or service interruption.

Threat Actor

FIN7 is known for using ransomware to encrypt organizational data and disrupt business operations. The group often combines data theft with ransomware and threatens to leak stolen information if the ransom is not paid.

SOC Detection Method

SOC analysts monitor for mass file encryption, deletion of backup files, unexpected shutdown or reboot commands, and unusual disk activity. Endpoint Detection and Response (EDR), Security Information and Event Management (SIEM), and backup monitoring tools help detect ransomware behavior early and reduce the impact of the attack.

APT GROUP PROFILES

An Advanced Persistent Threat (APT) is a cyberattack carried out by a skilled group. The attackers secretly enter a targeted network, stay inside for a long time to steal sensitive information without being detected. APT attacks are usually planned carefully and often target governments, businesses, and critical organizations.

1. APT29 (Cozy Bear)

Who They Are

APT29 is also known as **Cozy Bear**, is a Russian cyber espionage group believed to work for Russian intelligence agencies. The group is known for their stealthy cyberattacks to steal sensitive information from governments, research organizations, and critical industries. They stay inside a victim's network for a long time without being detected.

Industries Targeted

- Government
- Defense
- Healthcare
- Energy
- Technology
- Research organizations

Common Tactics and Techniques

Tactic	Technique
Initial Access	T1566 – Phishing
Persistence	T1053 – Scheduled Task
Credential Access	T1003 – OS Credential Dumping
Exfiltration	T1041 – Exfiltration Over C2 Channel

Known Campaign

SolarWinds Supply Chain Attack was one of the biggest cyberattacks linked to APT29 . The attackers inserted malicious code into a software update of SolarWinds Orion, a widely used IT management platform. When customers installed the infected update, the attackers gained secret access to their networks.

Due to this attack so many organizations are affected .

Incident Report: APT29 – SolarWinds Attack

Incident Name

SolarWinds Supply Chain Attack

Threat Actor

APT29 (Cozy Bear)

Year

2020

Incident Summary

APT29 attacked the software by adding malicious code to a software update. When customers installed the update, the attackers gained access to their systems without their knowledge.

Attack Method

- Added malware to a SolarWinds software update.
- Customers installed the infected update.
- Attackers gained access to their networks.

- Stole sensitive information.

Affected Organizations

- Government agencies
- Technology companies
- Private businesses

Impact

- Sensitive data was stolen.
- Thousands of organizations were affected.
- Attackers stayed hidden for several months.

Detection

SOC analysts detected the attack by monitoring:

- Unusual network activity
- Suspicious login attempts
- Unknown connections to external servers

2. APT41

Who They Are

APT41 is a Chinese threat group known for carrying out both cyber espionage and financially motivated attacks. Unlike many other APT groups, APT41 targets organizations for intelligence gathering while also conducting cybercrime for financial gain.

Industries Targeted

- Healthcare
- Telecommunications
- Software
- Manufacturing
- Gaming
- Government

Common Tactics and Techniques

Tactic	Technique
Resource Development	T1587 – Develop Capabilities
Persistence	T1547 – Boot or Logon Autostart Execution
Defense Evasion	T1027 – Obfuscated Files or Information
Collection	T1119 – Automated Collection

Known Campaign

APT41 has been linked to several software supply chain compromises and attacks against healthcare and telecommunications organizations. The group frequently develops custom malware to bypass security controls and maintain long-term access to victim environments.

Incident Report: APT41 – Operation CuckooBees

Incident Name

Operation CuckooBees

Threat Actor

APT41

Year

2022

Incident Summary

APT41 attacked several technology and manufacturing companies to steal important business information. The attackers entered the network, stayed hidden for a long time, and collected confidential data without the victims knowing.

Attack Method

- Gained access using phishing emails or software vulnerabilities.
- Installed malware on the victim's computer.
- Collected important files and business data.
- Sent the stolen data to their own servers.

Affected Organizations

- Technology companies
- Manufacturing companies
- Government organizations
- Healthcare companies

Impact

- Important business information was stolen.
- Companies faced financial and security problems.
- Attackers stayed inside the network for a long time.

Detection

SOC analysts found the attack by checking:

- Unusual login activity
- Suspicious programs running on computers
- Large data transfers
- Unknown network connections

3. FIN7

Who They Are

FIN7 is a financially motivated cybercriminal group that has operated for many years, targeting organizations to steal payment card information and deploy ransomware. The group is highly organized and often uses sophisticated phishing campaigns to gain initial access.

Industries Targeted

- Retail
- Hospitality
- Financial Services
- Restaurants
- Manufacturing

Common Tactics and Techniques

Tactic	Technique
Initial Access	T1566 – Phishing
Lateral Movement	T1021 – Remote Services
Credential Access	T1110 – Brute Force
Impact	T1486 – Data Encrypted for Impact

Known Campaign

FIN7 has conducted multiple phishing campaigns targeting businesses worldwide. In recent years, the group has also been associated with ransomware operations, where stolen data is used to pressure victims into paying large ransom demands.

i will provide a incident report on FIN7 known campaige

Incident Report: FIN7 – POS Malware Attack

Incident Name

POS Malware Attack

Threat Actor

FIN7

Year

2017

Incident Summary

FIN7 attacked restaurants and retail stores to steal customer payment card information. The attackers used phishing emails to enter the company's network and installed malware on **Point-of-Sale (POS)** systems.

Attack Method

- Sent phishing emails to employees.
- Installed malware on POS systems.
- Stole customers' payment card details.

Affected Organizations

- Restaurants
- Retail stores
- Hotels

Impact

- Payment card information was stolen.
- Companies lost money.
- Customer trust was affected.

Detection

SOC analysts detected the attack by monitoring:

- Phishing emails
- Unusual login activity
- Suspicious POS system activity
- Unknown network connections